# SEC-ENC-001 — Key Management Approval

**Product:** Vitora HMIS | **Supplier:** Nexora Consulting Ltd
**Evidence date:** 11 November 2026 | **Classification:** Internal and regulatory submission material

**UNSIGNED — FOR APPROVAL. This record does not assert that approval has been granted until signed by the named approvers.**

## 1. Purpose and approval scope

This record approves the operational key-management procedure supporting DHA SEC-ENC-001, including cloud PII encryption, backup encryption, key custody, access review, rotation, compromise response, and recovery evidence. It applies to the Vitora staging/production cloud service and does not replace facility-specific controller obligations.

## 2. Approved control posture

| Control | Approved requirement |
|---|---|
| PII encryption | Legacy direct identifiers use Fernet AES-128-CBC with HMAC-SHA256. The current organization-scoped path uses AES-256-GCM with tenant/model/field-bound authenticated data. |
| Key custody | Production and staging KEKs are separate Azure Key Vault keys. Workloads use managed identity and least-privilege crypto access. Raw KEK material is not exported to application code, clients, logs, or evidence bundles. |
| Backup encryption | Cloud database backups require `BACKUP_ENCRYPTION_KEY` and are encrypted using GPG AES-256 before upload. The passphrase is distinct from PII, JWT, database, and hub backup keys. |
| Hub independence | Facility Hub backups use the independent `HUB_BACKUP_ENCRYPTION_KEY` Fernet key, stored through host-protected secret storage. It must not be reused for cloud backup encryption. |
| Transport | Public API traffic requires TLS 1.2 or higher. Database connections require TLS. External HL7/MLLP connections require TLS with certificate verification. |

## 3. Key ownership and access

| Role | Responsibility |
|---|---|
| Platform Owner | Operates Azure Key Vault, Container Apps secret references, backup jobs, and restore exercises; grants least-privilege managed-identity roles. |
| Security Officer | Approves key access, reviews access evidence and exceptions, coordinates compromise response, and maintains rotation/recovery records. |

| | |
|---|---|
| DPO | Reviews privacy/security implications, breach assessment obligations, and evidence handling for restricted health data. |
| Engineering Lead | Maintains encryption code, regression tests, migration/re-encryption procedures, and change records. |

## 4. Rotation, recovery, and compromise procedure

1. Review KEK, application encryption, HMAC, backup, and hub-key inventories at least annually and after any material security event.
2. Rotate by creating/authorizing a new key version; retain prior versions for historical decryption until re-encryption or applicable retention expiry is complete.
3. Test decrypt/restore continuity before disabling an old key version.
4. On suspected compromise, open a Severity 1 incident unless formally downgraded; restrict the affected key where safe, issue a replacement, identify affected data/backups/hubs, re-encrypt as required, and review access/audit records.
5. Record the change, approver, key version, affected scope, validation result, rollback plan, and DPO assessment.

**Current operational note:** Azure Key Vault evidence currently shows a 30-day pre-expiry notification action. Automatic key rotation is not represented as enabled by this approval; it requires separate change approval, workload compatibility testing, and a verified re-encryption/recovery exercise.

## 5. Approval

| Approver | Name | Signature | Date |
|---|---|---|---|
| Security Officer | | | |
| Data Protection Officer | | | |
| Platform Owner | | | |
| CTO / Engineering Lead | | | |

Supporting design: docs/encryption-implementation-specification.md. Attach signed PDF only after all signature fields are completed. Do not place encryption keys, passphrases, tokens, or private certificates in this record.